

Authentication and Authorisation Notes

=====

WHAT IS AUTHENTICATION?

Authentication is the process of **verifying the identity** of a user, device, or application.

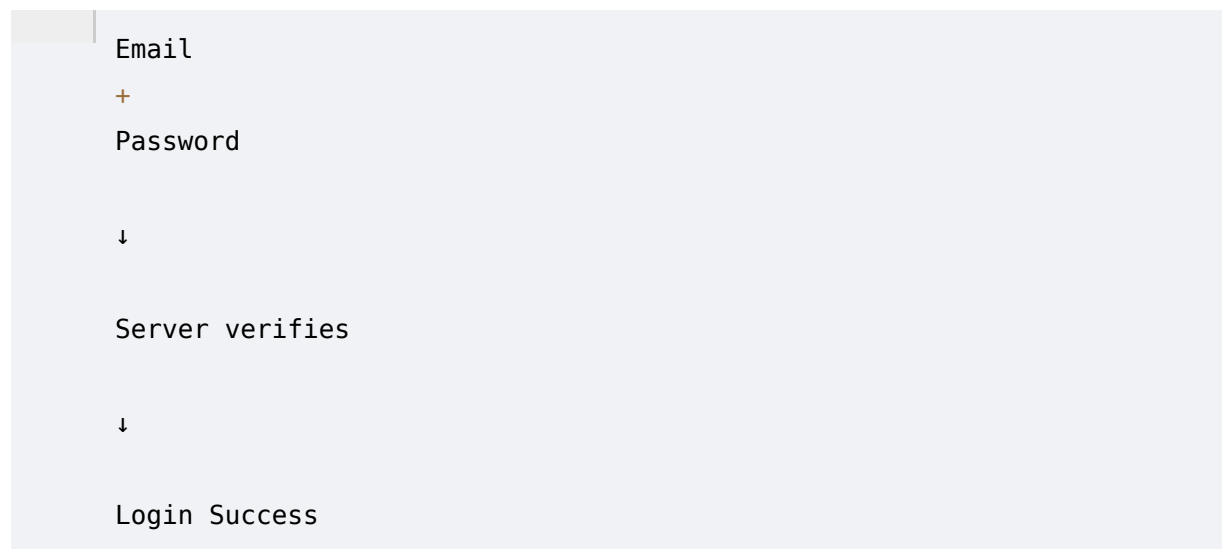
In simple words,

Authentication answers one question: "Who are you?"

The system checks whether you are really the person you claim to be.

EXAMPLE

You log into Instagram.



The server has verified your identity.

This is **Authentication**.

What is Authorization?

Authorization is the process of checking **what an authenticated user is allowed to access**.

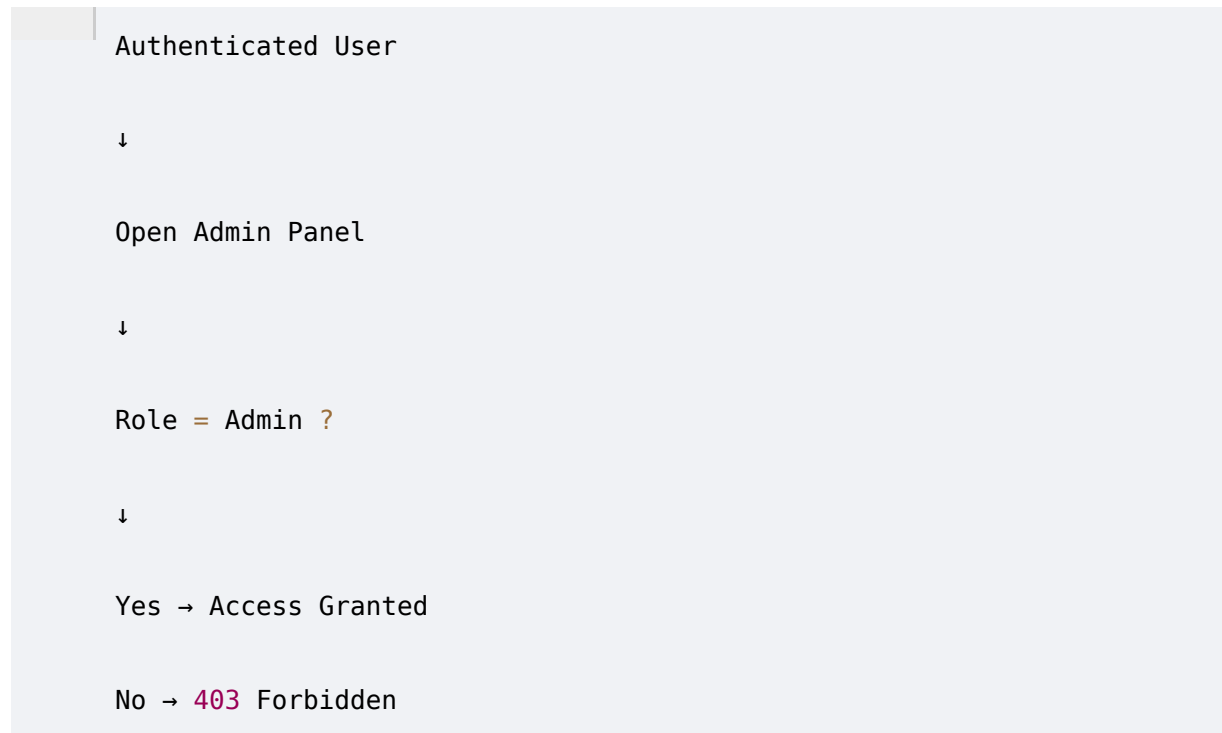
In simple words,

Authorization answers one question: "What are you allowed to do?"

EXAMPLE

You have already logged into Instagram.

Now you try opening the Admin Panel.



The server already knows **who you are**.

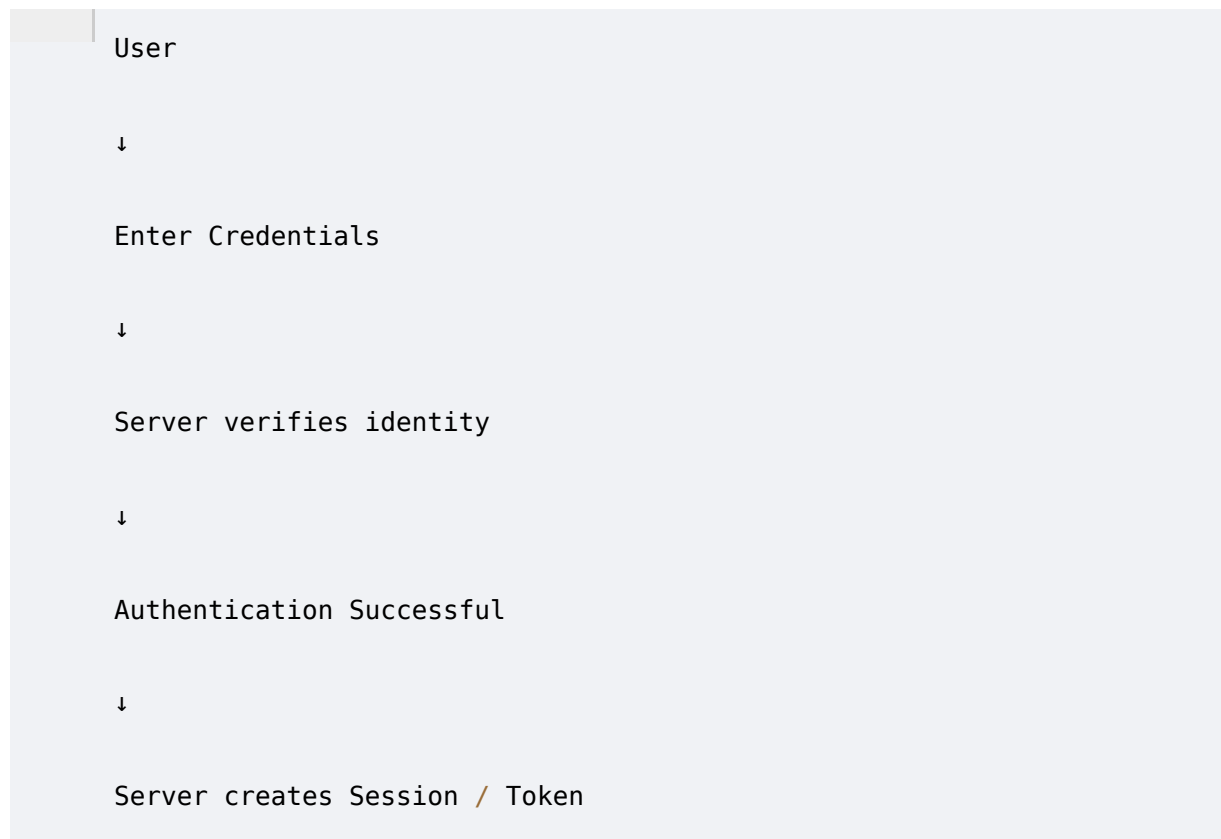
Now it is checking **your permissions**.

This is **Authorization**.

Authentication vs Authorization

Authentication	Authorization
Verifies identity	Verifies permissions
Answers "Who are you?"	Answers "What can you access?"
Happens first	Happens after authentication
Uses password, OTP, fingerprint	Uses roles and permissions

Authentication Flow



Three Authentication Factors

Authentication is based on three main factors.

1. SOMETHING YOU KNOW

Only you know this information.

Examples

- Password
- PIN
- Security Question

2. SOMETHING YOU HAVE

A physical object you own.

Examples

- Mobile Phone
- OTP
- Smart Card
- YubiKey
- Hardware Token

3. SOMETHING YOU ARE

Your biological identity.

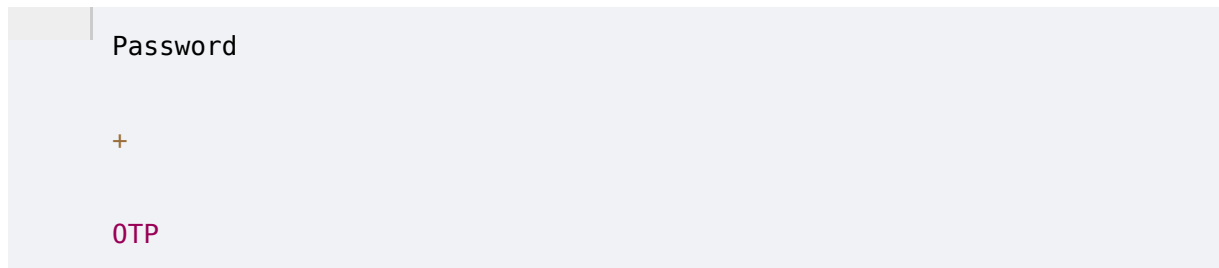
Examples

- Fingerprint
- Face Recognition
- Iris Scan
- Voice Recognition

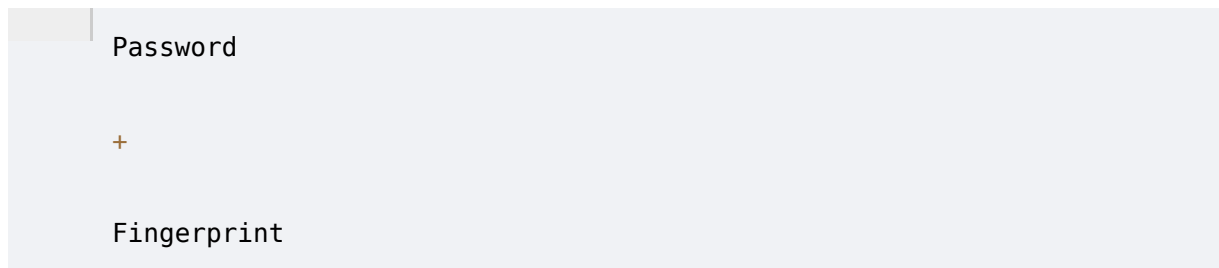
Multi-Factor Authentication (MFA)

If a system combines two or more authentication factors, it becomes **Multi-Factor Authentication (MFA)**.

Example



or



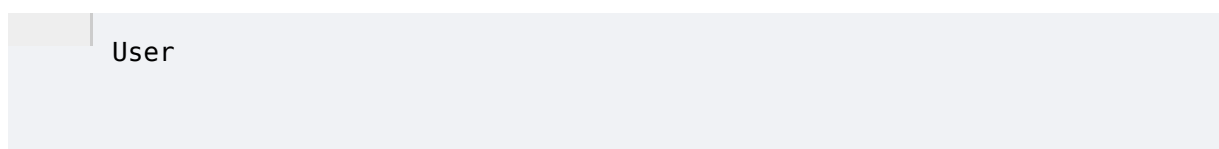
Using multiple factors makes authentication much more secure.

Authentication Methods

1. Password Authentication

The most common authentication method.

HOW IT WORKS



↓

Username + Password

↓

Server verifies

↓

Login Success

EXAMPLES

- Facebook
- Instagram
- Amazon

ADVANTAGES

- Easy to implement
- Familiar to users

DISADVANTAGES

- Passwords can be leaked
- Weak passwords are easy to guess

2. Session-Based Authentication

The server stores user information after login.

The browser stores only a Session ID inside a Cookie.

FLOW

Login

↓

Server creates Session

↓

Browser stores Cookie

↓

Every Request

↓

Cookie

EXAMPLES

- Banking Websites
- PHP
- Django
- Spring Boot

ADVANTAGES

- Secure
- Easy logout

DISADVANTAGES

- Difficult to scale
- Server must store every session

3. Token-Based Authentication

Instead of storing sessions,

the server generates a Token.

The client sends the token with every request.

FLOW

Login

↓

Token

↓

Client stores Token

↓

Every Request

↓

Authorization: Bearer Token

EXAMPLES

- Mobile Apps
- REST APIs

ADVANTAGES

- Stateless
- Easy to scale

DISADVANTAGES

- Token theft can be dangerous

4. JWT Authentication

JWT (JSON Web Token) is a **token format**, not an authentication method.

A JWT contains three parts.

Header

↓

Payload

↓

Signature

Example

xxxxx.yyyyy.zzzzz

Payload

```
{  
  "id": 12,  
  "role": "Admin"  
}
```

EXAMPLES

- React + Node
- Microservices

- Mobile Applications

ADVANTAGES

- Fast
- Stateless

DISADVANTAGES

- Logout is difficult
 - Large payload increases token size
-

5. API Key Authentication

The server issues a unique API Key.

```
x-api-key:  
ABCD123456
```

Every request includes the key.

EXAMPLES

- Google Maps API
- Weather API
- Internal APIs

ADVANTAGES

- Very simple

DISADVANTAGES

- Easy to leak
 - No user identity
-

6. Basic Authentication

The browser sends

```
username:password
```

encoded using Base64.

Example

```
Authorization:  
  
Basic YWRtaW46MTIzNA==
```

EXAMPLES

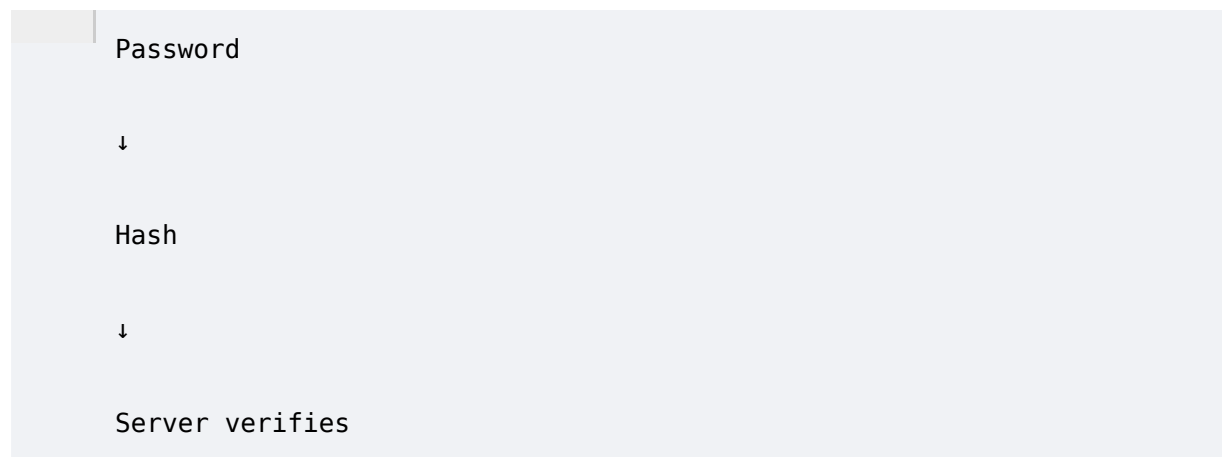
- Routers
- Legacy APIs

DISADVANTAGES

- Password is sent on every request
- Must always use HTTPS

7. Digest Authentication

Instead of sending the password,
the browser sends its hash.



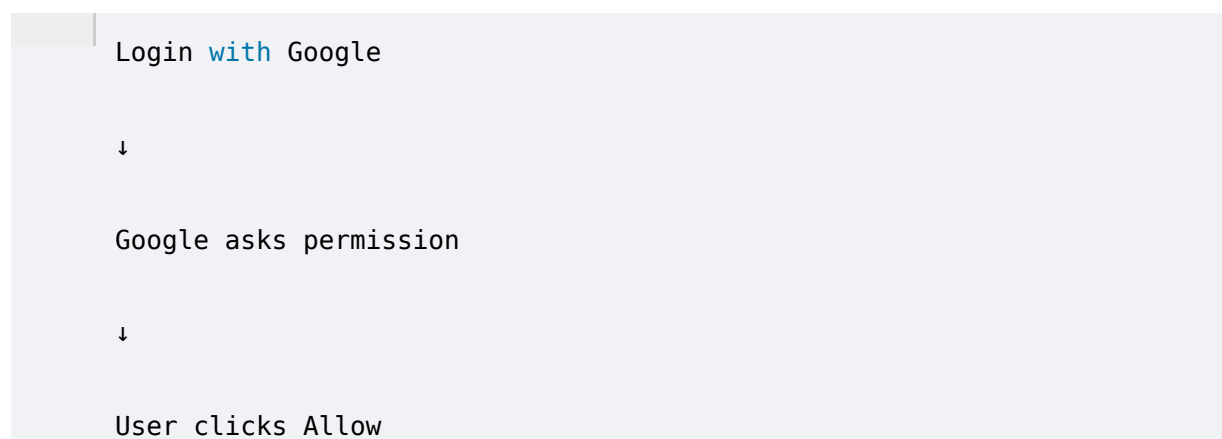
Safer than Basic Authentication,
but rarely used today.

8. OAuth 2.0

OAuth is **not a login system**.

It is an **authorization framework** that allows one application to access another application's resources with permission.

Example



↓

Google sends Access Token

Examples

- Login with Google
- Login with GitHub

9. OpenID Connect (OIDC)

OIDC is built on top of OAuth 2.0.

OAuth gives

Permission

OIDC gives

Identity

Example

Google Sign In

↓

Name

Email

Profile Picture

10. SAML Authentication

XML-based authentication used by enterprises.

EXAMPLES

- Microsoft
- SAP
- Oracle

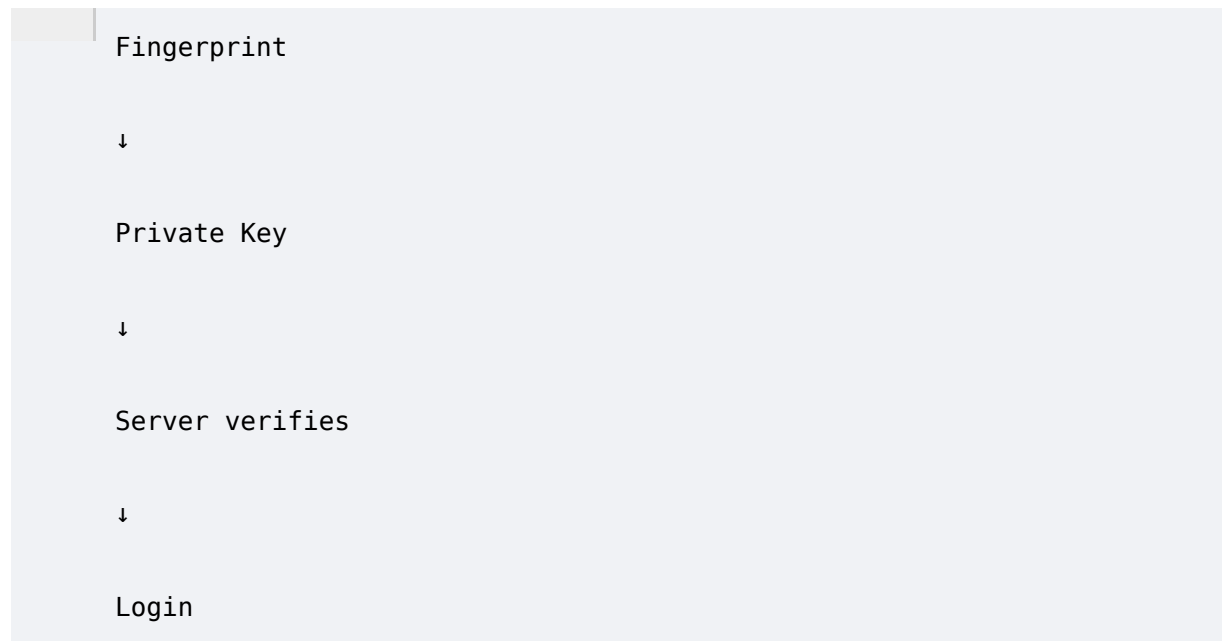
Used for

Single Sign-On (SSO).

11. Passkeys (FIDO2/WebAuthn)

No password is required.

Authentication uses public-key cryptography.



Examples

- Apple
- Google
- GitHub

12. Certificate Authentication

Instead of passwords,

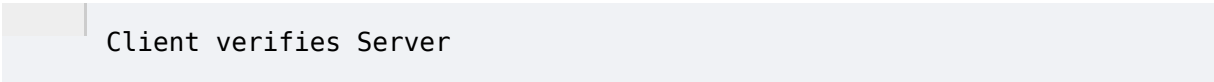
users authenticate using digital certificates.

Used in

- VPNs
- Government portals
- Enterprise systems

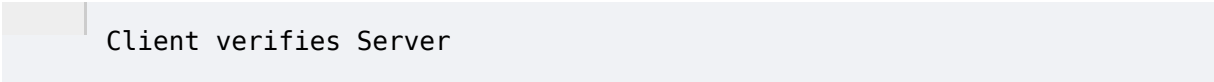
13. Mutual TLS (mTLS)

Normally



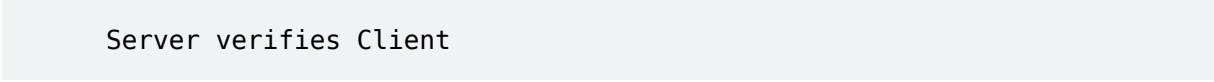
```
graph TD; A[Client verifies Server];
```

In mTLS



```
graph TD; A[Client verifies Server];
```

AND



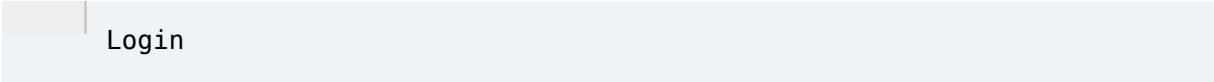
```
graph TD; A[Server verifies Client];
```

Used in

- Banks
- Payment Gateways
- Microservices

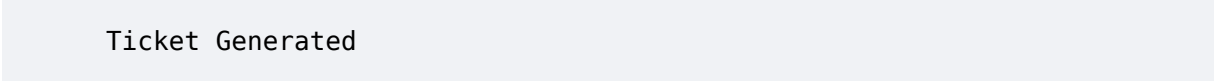
14. Kerberos

Authentication uses **Tickets** instead of repeatedly sending passwords.



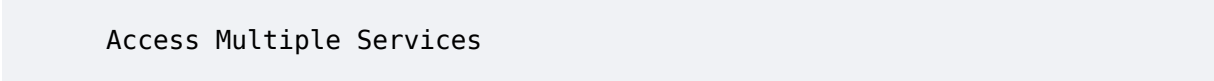
```
graph TD; A[Login];
```

↓



```
graph TD; A[Ticket Generated];
```

↓



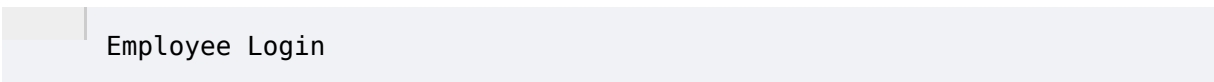
```
graph TD; A[Access Multiple Services];
```

Commonly used in

- Windows Active Directory

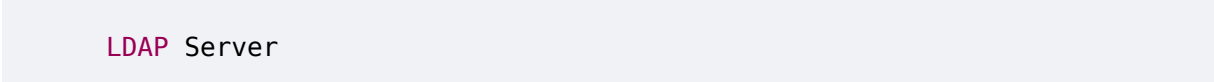
15. LDAP Authentication

LDAP stores all employee accounts in one central directory.



```
graph TD; A[Employee Login];
```

↓



```
graph TD; A[LDAP Server];
```

↓

Verify User

Used in

- Microsoft
- IBM
- Oracle

16. Biometric Authentication

Identity is verified using biological characteristics.

Examples

- Fingerprint
- Face Recognition
- Iris
- Voice

17. OTP Authentication

Authentication using a One-Time Password.

Phone Number

↓

OTP

↓

Verify

↓

Login

Examples

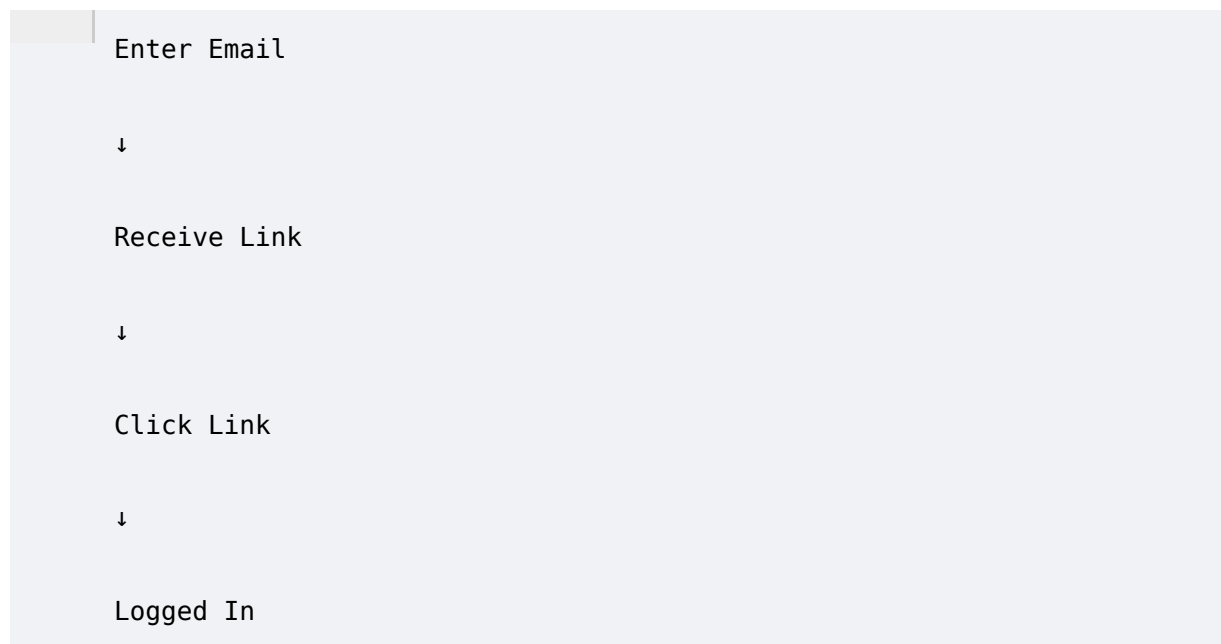
- Paytm

- PhonePe
- WhatsApp

18. Magic Link Authentication

No password is required.

A login link is sent to the user's email.



Examples

- Notion
- Slack
- Medium

Authentication Methods Summar

Method	Best Used For
Password	General websites
Session	Traditional web apps
Token	Mobile apps & APIs
JWT	Microservices & SPAs

API Key	Public APIs
Basic Auth	Legacy systems
OAuth 2.0	Third-party authorization
OIDC	Single Sign-On (SSO)
SAML	Enterprise SSO
Passkeys	Passwordless login
MFA	High-security accounts
Certificate	VPNs & Enterprises
mTLS	Service-to-Service communication
Kerberos	Windows Domains
LDAP	Enterprise directories
OTP	Phone verification
Magic Link	Passwordless web login

Golden Interview Points

- Authentication verifies **identity**.
- Authorization verifies **permissions**.
- Authentication always happens **before** Authorization.
- JWT is a **token format**, not an authentication method.
- OAuth 2.0 is an **authorization framework**, not an authentication protocol.
- OIDC adds **identity** on top of OAuth 2.0.
- Sessions are **stateful**, while Tokens/JWT are generally **stateless**.

Official Resources (Must Read)

- **OWASP Authentication Cheat Sheet** –
https://cheatsheetseries.owasp.org/cheatsheets/Authentication_Cheat_Sheet.html
- **OWASP Authorization Cheat Sheet** –
https://cheatsheetseries.owasp.org/cheatsheets/Authorization_Cheat_Sheet.html
- **Microsoft Learn – Authentication vs Authorization** –
<https://learn.microsoft.com/entra/identity-platform/authentication-vs-authorization>
- **OAuth 2.0** – <https://oauth.net/2/>
- **OpenID Connect** – <https://openid.net/connect/>
- **JWT** – <https://jwt.io/>
- **WebAuthn** – <https://webauthn.io/>